



Confidence in a connected world.



”Recent view in the Internet threat environment and its counter measures”

Tadashi Yamanouchi

Symantec Japan Research Institute, Inc.

August 7, 2007

1 Internet Security Threat Report

2 Attack Trends

3 Vulnerability Trends

4 Malicious Code Trends

5 Counter measures

1 Internet Security Threat Report

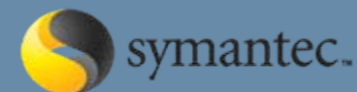
2 Attack Trends

3 Vulnerability Trends

4 Malicious Code Trends

5 Counter measures

The Global Intelligence Network



4 Symantec SOCs

+

74 Symantec Monitored Countries

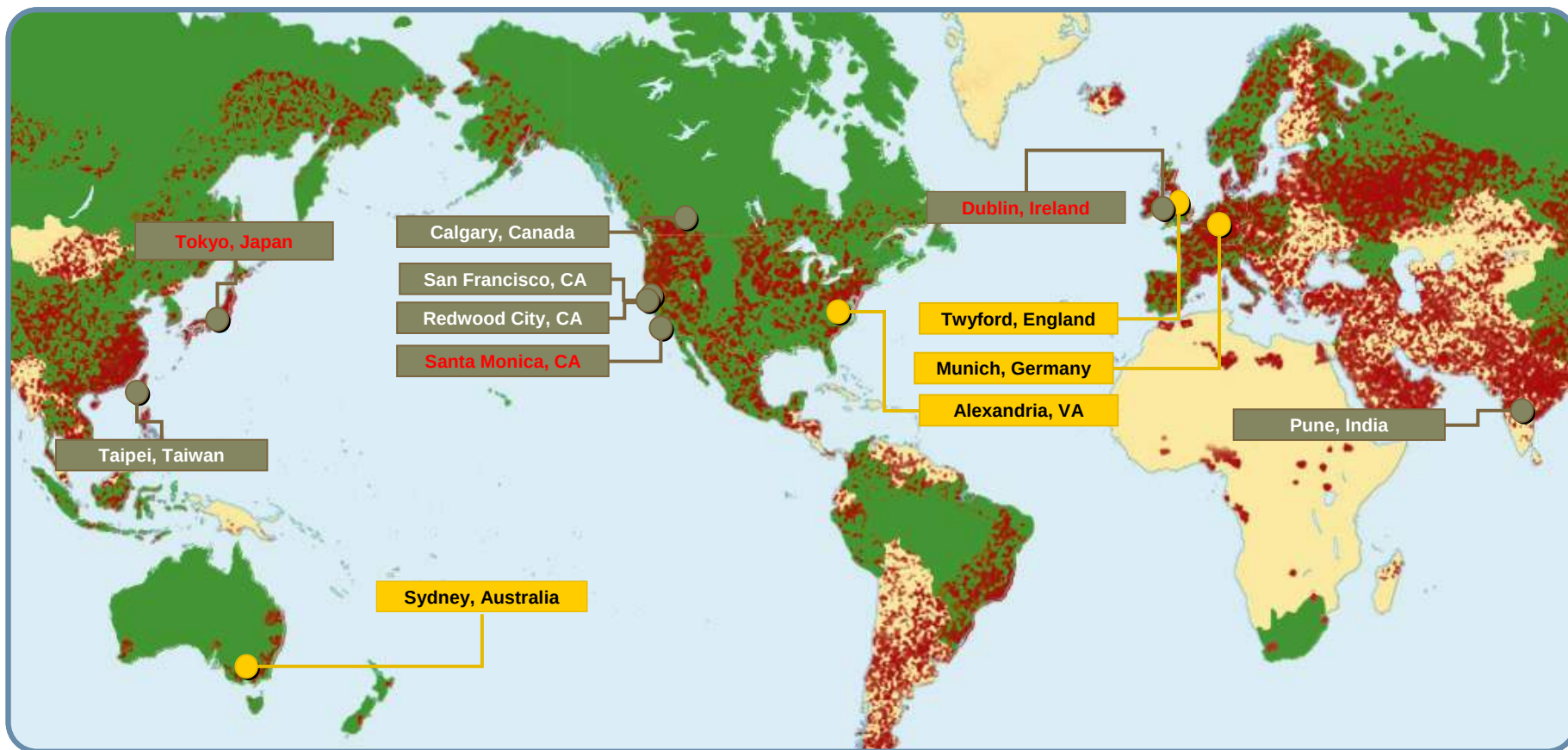
+

40,000+ Registered Sensors in 180+ Countries

+

8 Symantec Security Response Centers

>6,200 Managed Security Devices + 120 Million Systems Worldwide + 30% of World's email Traffic + Advanced Honeypot Network



Global Intelligence is data sources for “Internet Security Threat Report”



- **™ Global Intelligence Network**

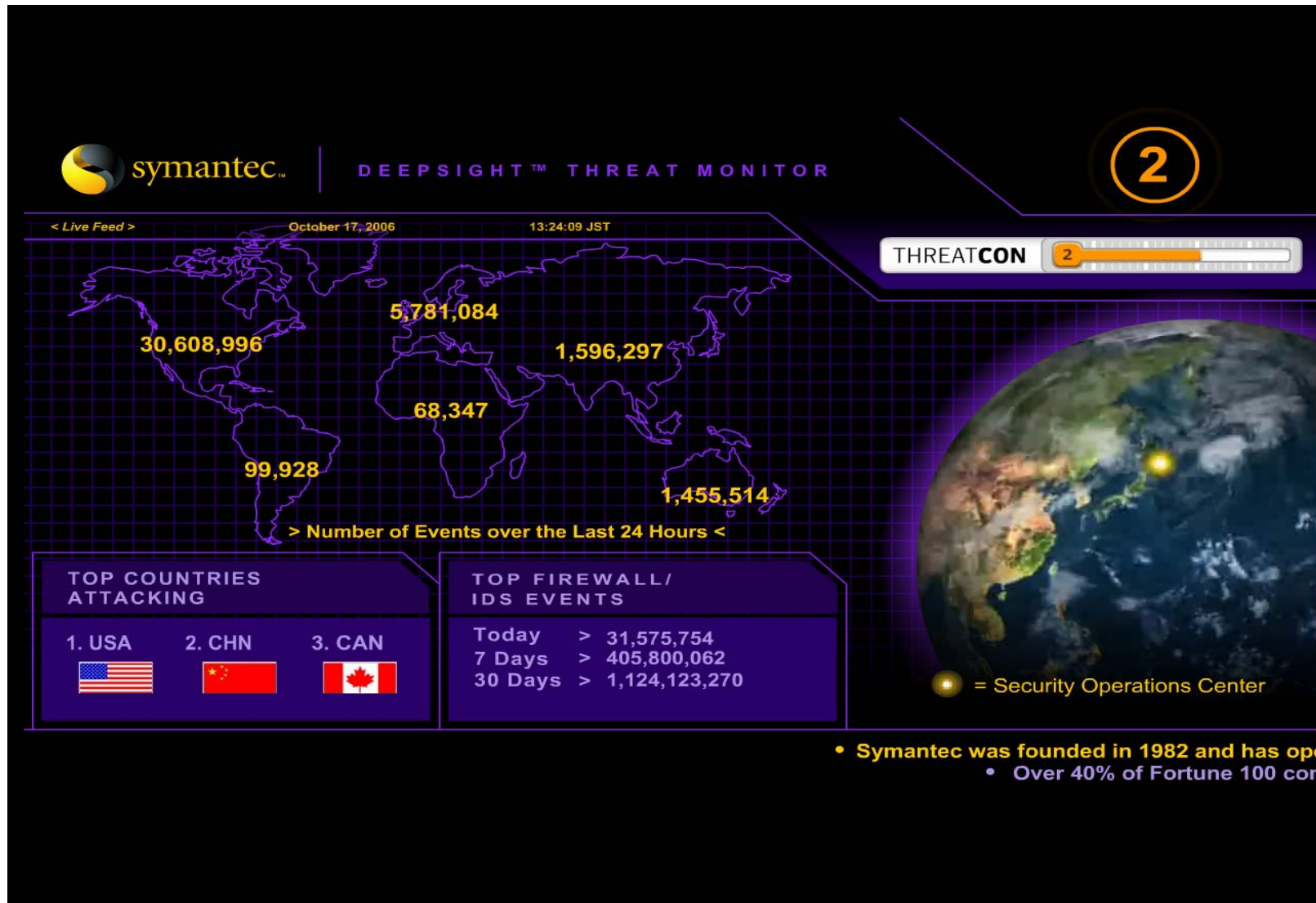
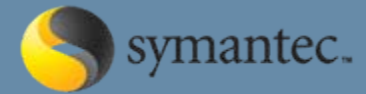
- Database of 20,000+ Vulnerabilities
- Attack Quarantine System (Honeypot)
- 40,000 registered sensors in 180 countries.
- 120 million desktop, gateway and server antivirus installations.
- 2,000,000 decoy accounts in the Symantec Probe Network - 30% of all email traffic
- 200,000 Malicious Code Submissions per month

- **Global Coverage**

- 4 Security Operations Centers, 8 Symantec Research Centers.
- 500+ analysts, 6200 managed security devices.

Internet Security Threat Report

Image of aggregation data



Internet Security Threat Report

What the ISTR



- What the ISTR is:
 - A detailed report on trends that **Symantec** sees.
 - Based on real, **empirical** data collected by the Global Intelligence Network.
 - Only publicly available report to offer a **complete** view of the current Internet security landscape.
 - Identifies and **analyzes** attacker methods and preferences.
 - Vendor **neutral**.
- What the ISTR is not:
 - A **survey** of opinions.
 - Product driven **marketing**.
 - Scientific **certainty**.

1 Internet Security Threat Report

2 Attack Trends

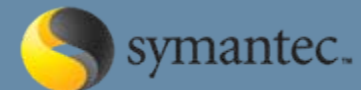
3 Vulnerability Trends

4 Malicious Code Trends

5 Counter measures

Attack Trends

Malicious Activity

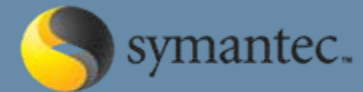


- ▶ Between July 1st and December 31st the United States was the top country for malicious activity (raw numbers) with 31% of the overall proportion. China was ranked second with 10%.
- ▶ When accounting for Internet populations, Israel was the top country with 9% followed by the Taiwan region with 8%. Six of the top ten countries in this metric were located in EMEA.

Overall Rank	Country	Overall Proportion	Malicious Code Rank	Spam Host Rank	Command and Control Server Rank	Phishing Host Rank	Bot Rank	Attack Rank
1	United States	31%	1	1	1	1	2	1
2	China	10%	3	2	4	8	1	2
3	Germany	7%	7	3	3	2	4	3
4	France	4%	9	4	14	4	3	4
5	United Kingdom	4%	4	13	9	3	6	6
6	South Korea	4%	12	9	2	9	11	9
7	Canada	3%	5	23	5	7	10	5
8	Spain	3%	13	5	15	16	5	7
9	Taiwan	3%	8	11	6	6	7	11
10	Italy	3%	2	8	10	14	12	10

Attack Trends

Underground Economy Servers

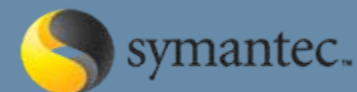


- ▶ Trading in credit cards, identities, online payment services, bank accounts, bots, fraud tools, etc.
- ▶ Ranked according to geographic location of the server and the location of banks.
- ▶ The United States had the highest proportion of underground economy servers that Symantec observed with 51%. 7 of the top ten were located in EMEA.
- ▶ 86% of banks whose credit cards were stolen were located in the United States followed by the United Kingdom (7%) and Canada (1%).

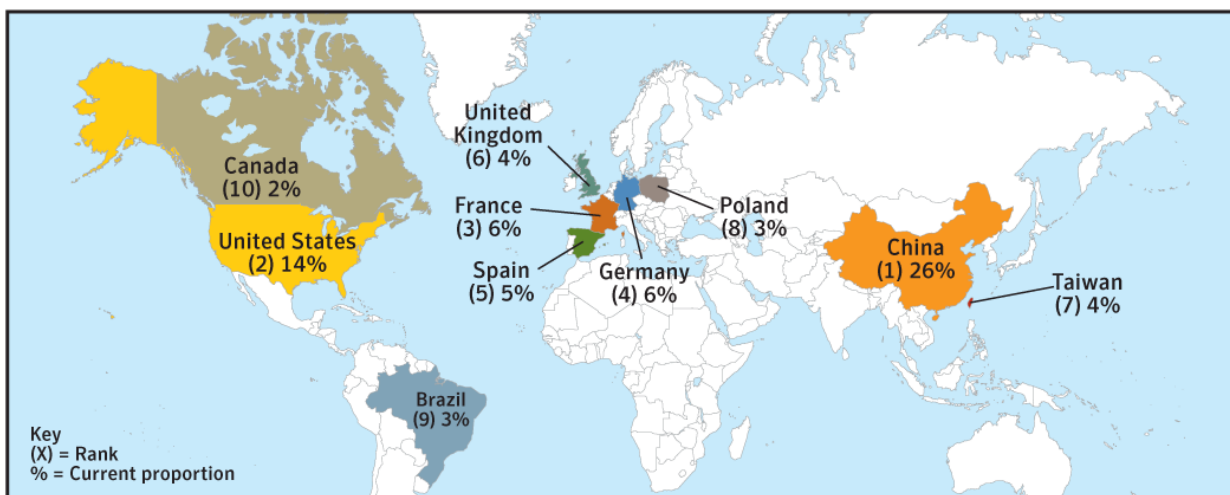
Item	Advertised Price (in US Dollars)
United States-based credit card with card verification value	\$1–\$6
United Kingdom-based credit card with card verification value	\$2–\$12
An identity (including US bank account, credit card, date of birth, and government issued identification number)	\$14–\$18
List of 29,000 emails	\$5
Online banking account with a \$9,900 balance	\$300
Yahoo Mail cookie exploit—advertised to facilitate full access when successful	\$3
Valid Yahoo and Hotmail email cookies	\$3
Compromised computer	\$6–\$20
Phishing Web site hosting—per site	\$3–5
Verified PayPal account with balance (balance varies)	\$50–\$500
Unverified PayPal account with balance (balance varies)	\$10–\$50
Skype account	\$12
World of Warcraft account—one month duration	\$10

Attack Trends

Bot Networks



- ▶ During the current reporting period Symantec observed an average of **63,912 active bot network computers per day**, an 11% increase over the first half of the year. The worldwide total of distinct **bot-infected computers** that Symantec identified rose to just over **6,049,594 - a 29% increase**.
- ▶ China has increased its global proportion of bot-infected computers to 26% while the United States continues to decline. EMEA countries, with the exception of the U.K., showed the largest increase.
- ▶ Bots and bot networks are an extremely valuable resource for attackers. Bots are being used for criminal activities such as fraud, DoS extortion attempts, malicious code propagation, spam and the distribution of adware and spyware onto systems.



1 Internet Security Threat Report

2 Attack Trends

3 Vulnerability Trends

4 Malicious Code Trends

5 Counter measures

Vulnerability Trends

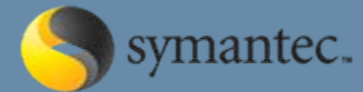
Some Metrics



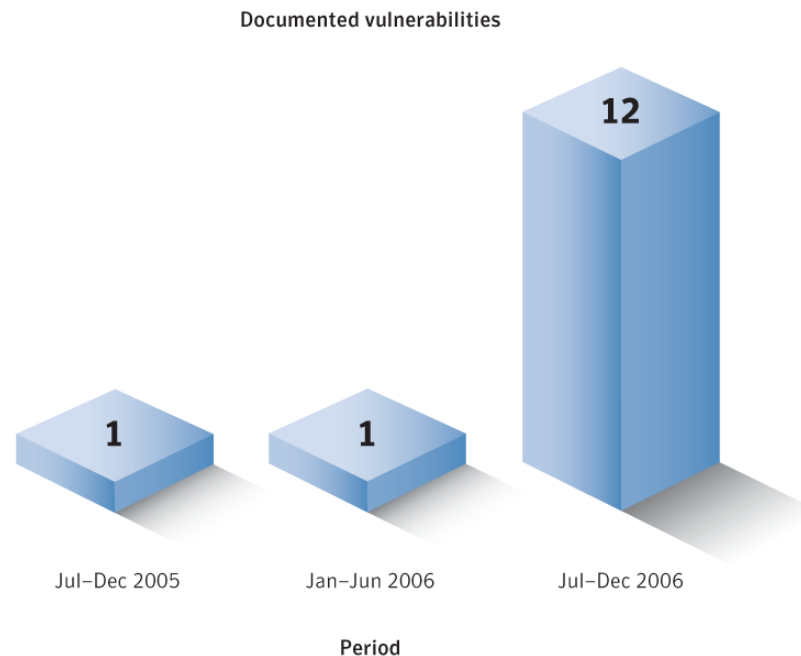
- ▶ Vulnerabilities are design or implementation errors in information systems that can result in a compromise of the confidentiality, integrity, or availability of information stored upon or transmitted over the affected system.
- ▶ Symantec documented **2,526 vulnerabilities** in the current reporting period, 12% higher than the previous reporting period.
- ▶ Severity classification: High severity 4%, Medium severity 69% and Low severity 27%.
- ▶ **Web applications constituted 66%** of all documented vulnerabilities. **77% of easily exploitable vulnerabilities** affected web applications.
- ▶ 79% of all vulnerabilities were considered easily exploitable, 94% of which were remotely exploitable.
- ▶ The W.O.E. for enterprise vendors was 47 days. Average exploit development time of 5 days and average patch development of 52 days.
- ▶ 25% of exploit code was released less than one day after the publication of a vulnerability. 31% was released between one and six days.

Vulnerability Trends

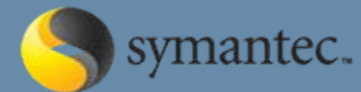
Zero-day



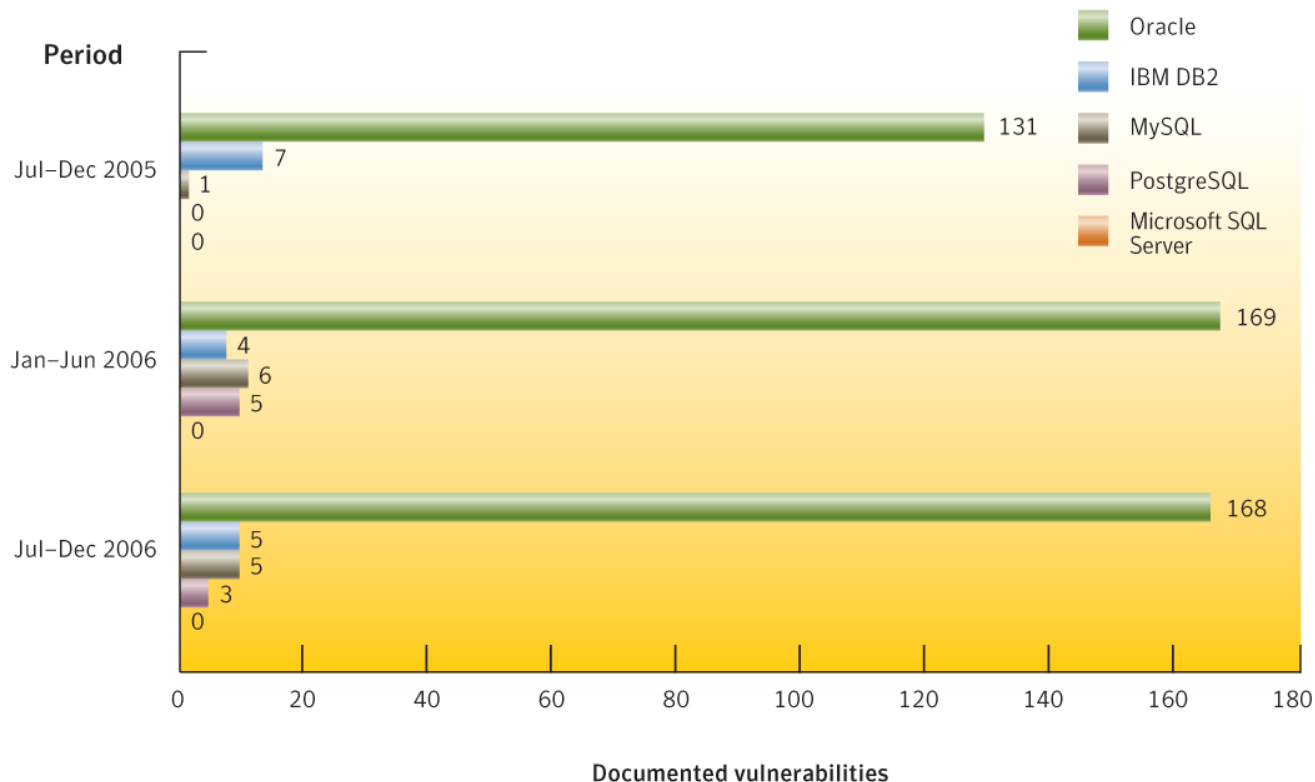
- ▶ Key Definition: “A zero-day vulnerability is one for which there is sufficient public evidence to indicate that the vulnerability has been exploited in the wild prior to being publicly known.”
- ▶ Zero-day vulnerabilities represent a serious threat in many cases because there is no patch available for them and because they will likely be able to evade purely signature-based detection.
- ▶ This period, we documented 12 zero-day vulnerabilities, a significant increase over the previous two reporting periods.



Vulnerability Trends Databases

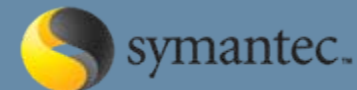


- ▶ Oracle databases have the highest number of documented vulnerabilities of the major database vendors - 168. Oracle's large markets share makes it a prime target for database related attacks.
- ▶ This indicates that the information kept on these types of databases are extremely valuable.
- ▶ Microsoft SQL has not had *any* documented vulnerabilities in the past three reporting periods.

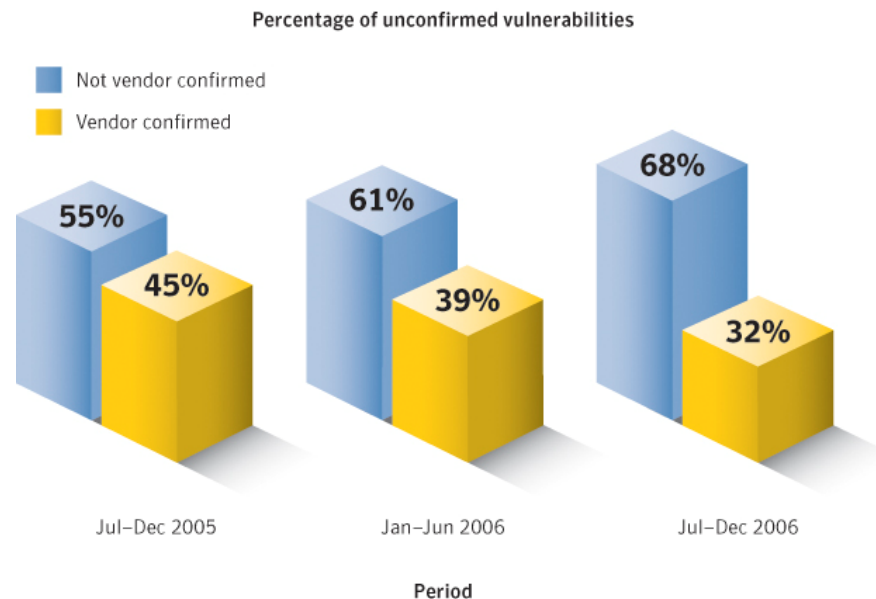


Vulnerability Trends

Vendor Responsiveness

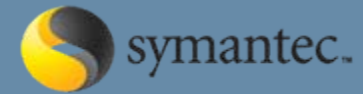


- ▶ Key definition: “Vendor responsiveness is measured by the proportion of vulnerabilities that remains unconfirmed by the vendor, and therefore un-patched, over time.”
- ▶ In the current reporting period, 68 percent of documented vulnerabilities were not confirmed by the affected vendor, an increase from 61% the previous reporting period.
- ▶ Targeted malicious code taking advantage of vulnerabilities, especially older, un-patched vulnerabilities is serious issues for organizations with older legacy systems such as government.

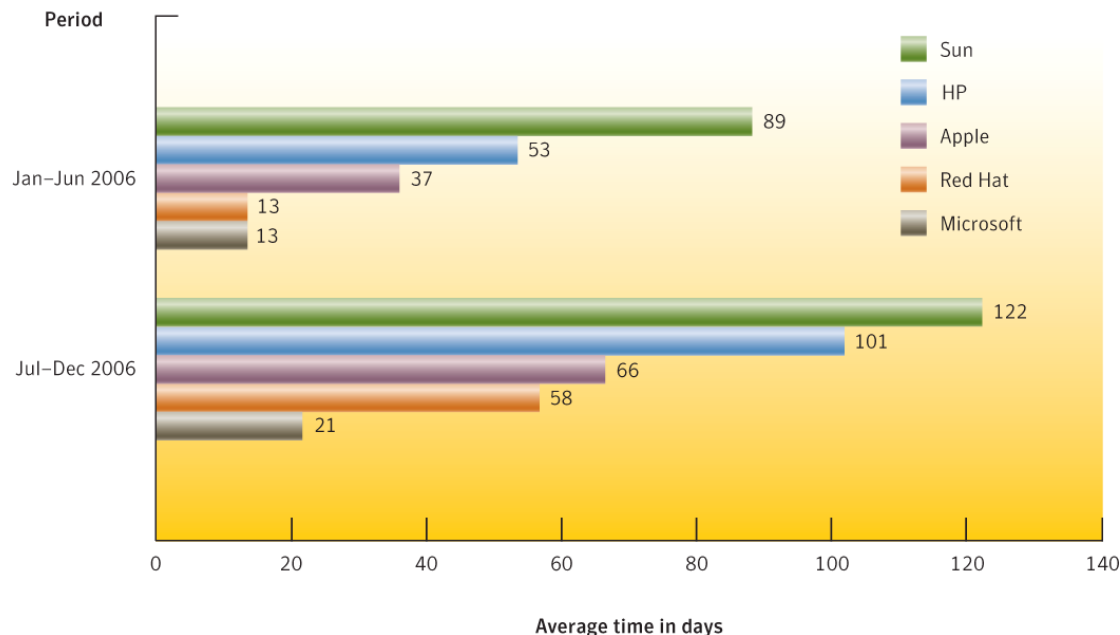


Vulnerability Trends

Patch Development Time



- ▶ The time period **between the disclosure date of a vulnerability and the release date of an associated patch** is known as the “patch development time
- ▶ All vendors reported longer average patch development times. Sun and HP had the longest patch development times with 122 and 101 days respectively. Microsoft had the shortest patch development time with 21 days.
- ▶ Sample set size and severity are key components - the majority of vulnerabilities are medium severity and affect 3rd party components. Microsoft had the highest number of severe vulnerabilities with 12.

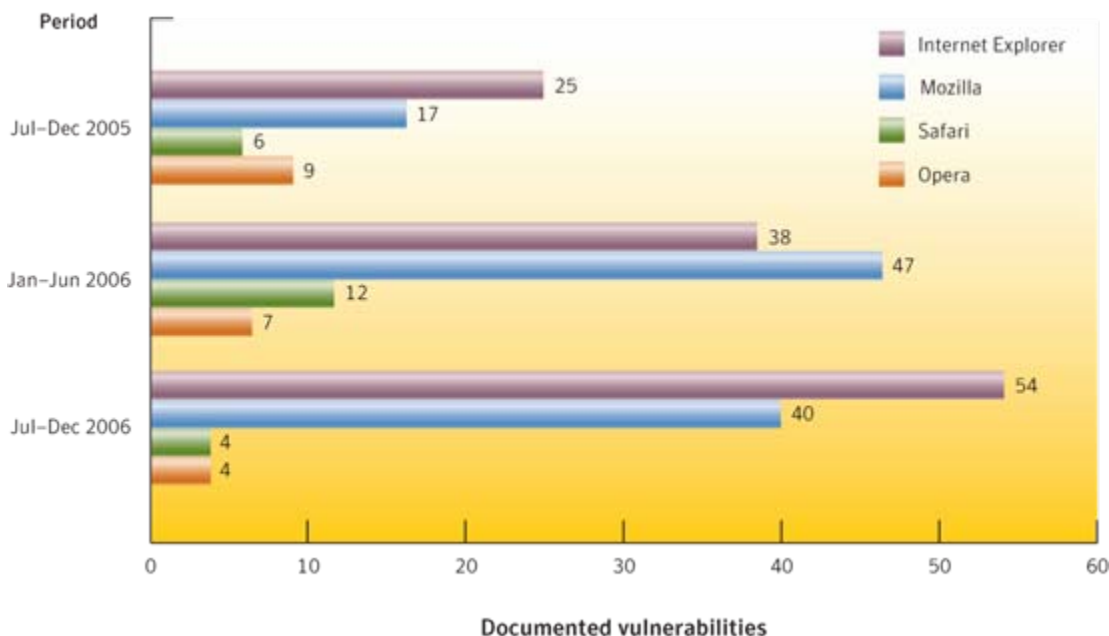


Vulnerability Trends

Browser Vulnerabilities and W.O.E.



- ▶ IE was the most targeted browser with 77% of all targeted attacks.
- ▶ Microsoft had the highest number of documented vulnerabilities with 54 followed by Mozilla with 40. Microsoft was the only vendor to have a documented high severity browser vulnerability and the only vendor to increase its vulnerability count.
- ▶ Mozilla had the shortest window of exposure with 2 days followed by IE with 10 days. Apple had the longest window of exposure at 61 days - very limited sample set.



1 Internet Security Threat Report

2 Attack Trends

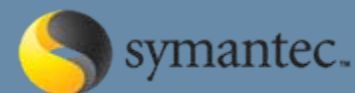
3 Vulnerability Trends

4 Malicious Code Trends

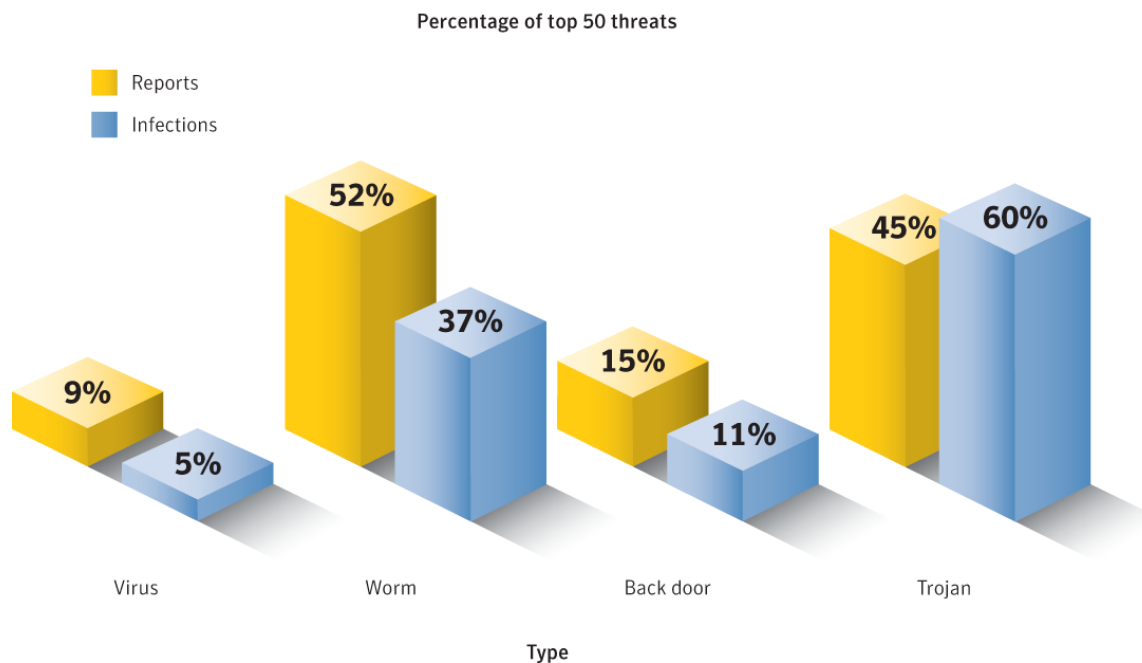
5 Counter measures

Malicious Code Trends

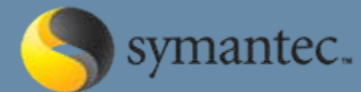
Types



- ▶ Introduction of AVPing data in this report - provides a comparison between reports (volume) and ***potential/attempted*** infections. In some cases, a threat may be widely reported but not cause a wide number of infections and vice versa.
- ▶ Supports Symantec's assertion that Trojans are on the rise and may constitute a greater threat because they tend to exploit web browser and zero-day vulnerabilities. Trojans reported to Symantec increase from 23% in the last reporting period to 45% in the current period and represent 60% of malicious code by potential/attempt infections.

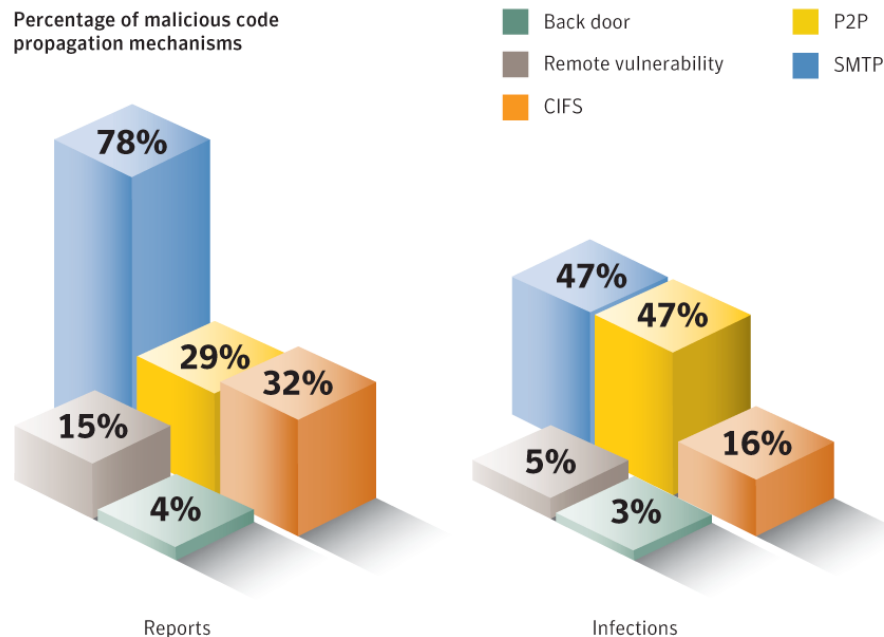


Malicious Code Trend Propagation Vectors



- ▶ SMTP propagation remains the number one propagation mechanism by volume at 78%. This is a decrease from 98% in the previous reporting period. This is due to an increase in attackers diversifying their infection attempts and a decrease in mass mailer reports.
- ▶ When compared with potential/attempted infections, SMTP and P2P account for nearly half of all propagation methods. The discrepancy between reports and potential/attempted infections is likely due to the presence of mass mailers.

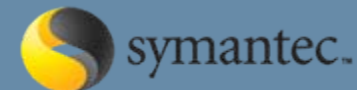
Percentage of malicious code
propagation mechanisms



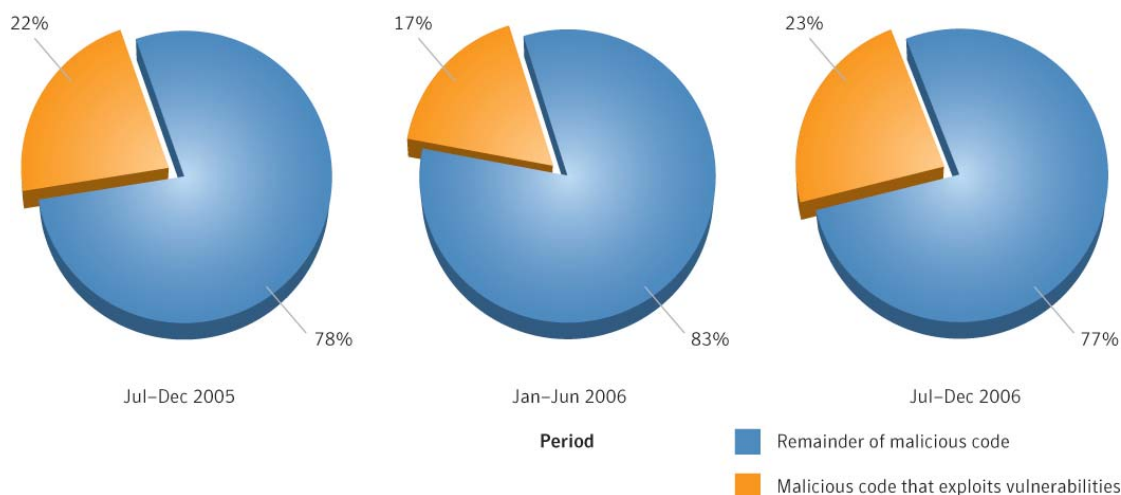
Source

Malicious Code Trends

Vulnerability Exploitation



- ▶ 23% of the 1,318 documented malicious code instances exploited vulnerabilities. This is an increase from the 17% in the previous reporting period.
- ▶ Malicious code that exploits vulnerabilities in 3rd party applications is on the rise - five zero-day exploits were released for vulnerabilities in Microsoft Office during the current reporting period.
- ▶ Malicious code that exploits vulnerabilities is strongly correlated with zero-day vulnerabilities.

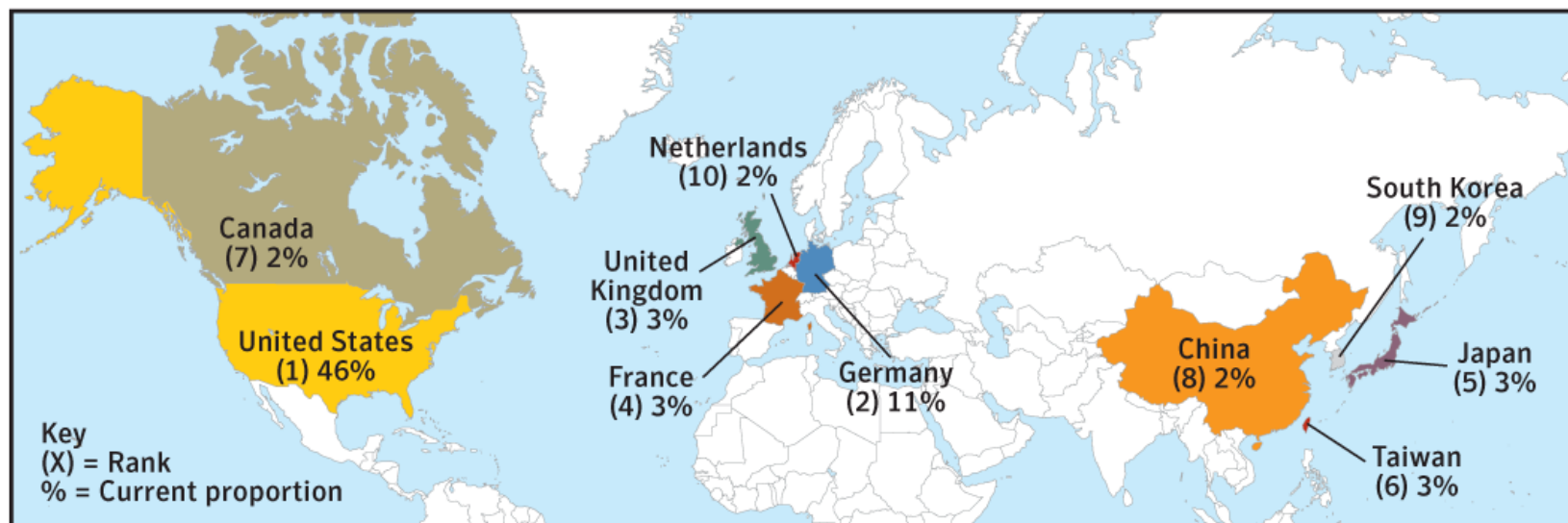


Phishing

Top Countries Hosting Phishing Sites

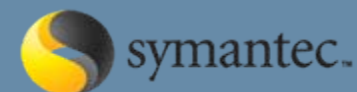


- ▶ 46% of known phishing sites were located in the United States followed by Germany with 11% and the United Kingdom with 3%
- ▶ The U.S. is number one because a large number of Web-hosting providers—particularly free Web hosts—are located in the United States. Furthermore, the United States has the highest number of Internet users in the world, and it is home to a large number of Internet-connected organizations, both large and small.
- ▶ Germany has the largest number of Web-hosting providers in Europe. By hosting with large providers, phishers gain the advantage of obscurity due to the large number of sites hosted and the difficulty in tracking down a phishing site and shutting it down.



Spam

Country of Origin



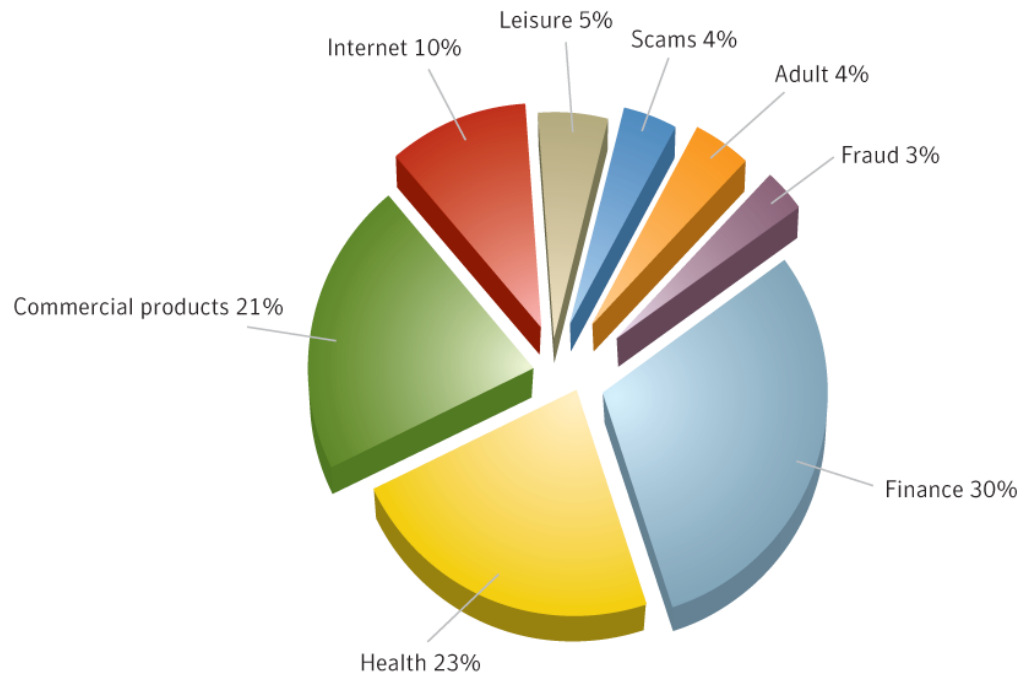
- ▶ 44% of all spam originated in the United States, a drop from 49% in the previous reporting period. Undetermined EU countries rank second with 7% followed by China with 6%
- ▶ Distribution of Spam Zombies - U.S. 10%, China 9%, Germany 8%. 5 of the top ten spam zombie countries are in EMEA.
- The point we want to make here is that **spammer methods are evolving to include more decentralized, redundant distribution systems** to avoid detection and increase their success.

Country	Jul-Dec 2006	Jan-Jun 2006
United States	44%	49%
Undetermined EU Countries	7%	4%
China	6%	11%
Canada	4%	5%
United Kingdom	3%	4%
South Korea	3%	5%
Japan	3%	2%
France	3%	2%
Spain	3%	2%
Poland	3%	2%

Spam Categories



- ▶ Spam related to Financial products or services was the top category with 30% followed by Health with 23%
- ▶ Finance grew from 15% - 30% primarily because of the rise in “pump and dump” spams and has allowed spammers to generate revenue almost immediately. Spam targeting adult products or services dropped in direct proportion to the increase in Financial spam



- The current threat environment is characterized by an **increase in data theft, data leakage, and the creation of malicious code that targets specific organizations.**
- **Attackers are refining their methods and consolidating assets** to create global networks that support coordinated criminal activity
- **Increased inter-operability** between diverse threats - **blended threats +**
- Year of the **zero-day, targeted malicious code** and the exploitation of medium severity vulnerabilities
- High levels of malicious activity across the Internet with **increases in bot networks, phishing, spam and trojans.**

1 Internet Security Threat Report

2 Attack Trends

3 Vulnerability Trends

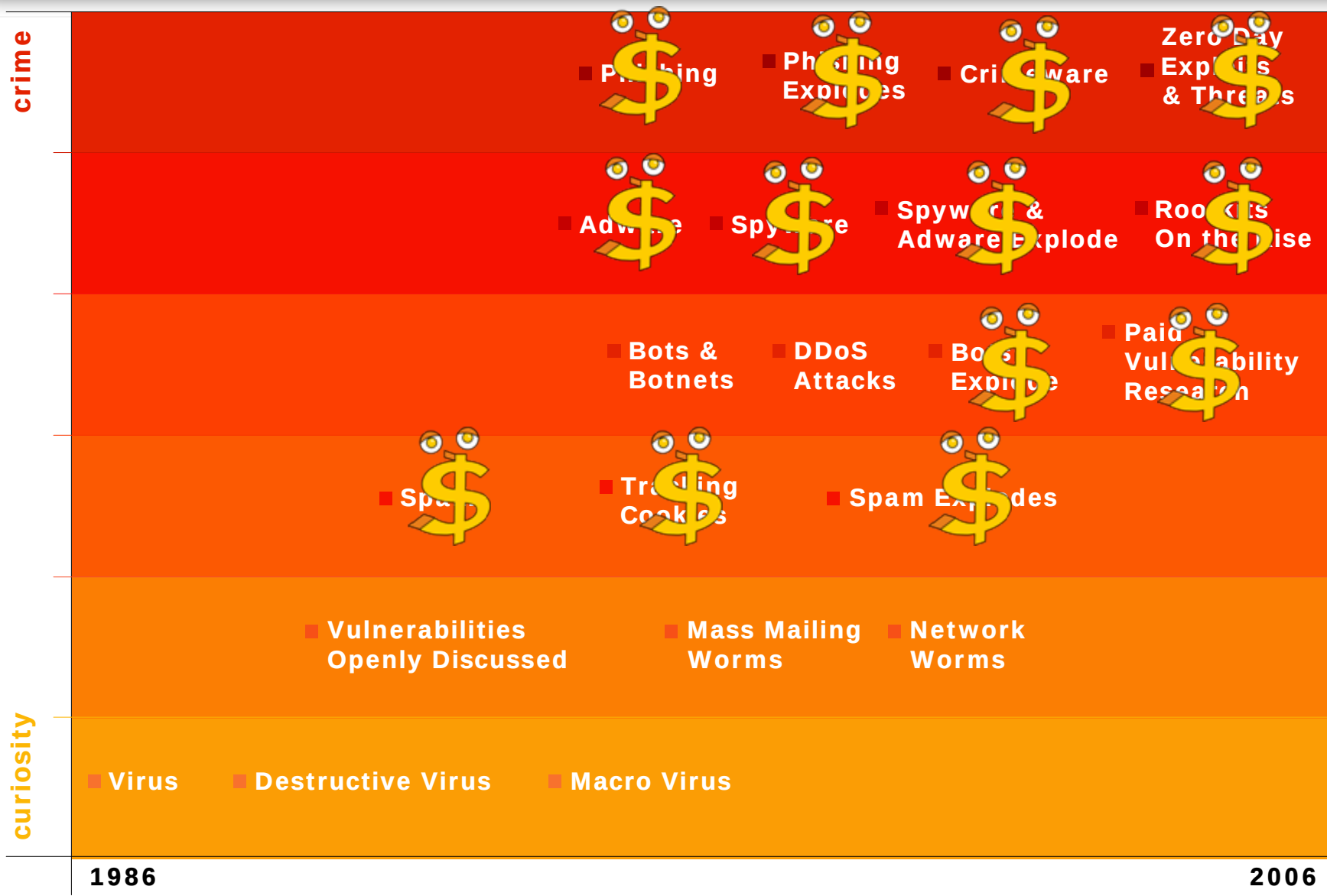
4 Malicious Code Trends

5 Counter measures

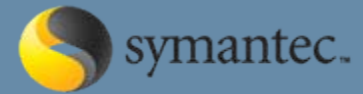
The Shifting Threat Landscape...



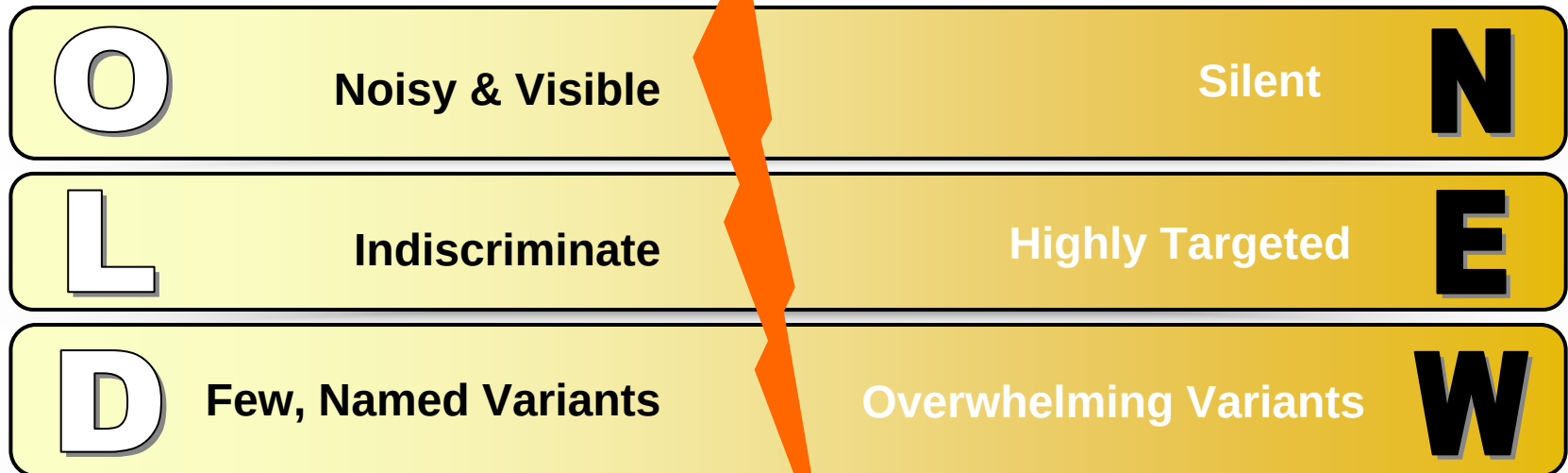
Threat Evolution Timeline



As Threat Landscape Changes, Technology Must as Well

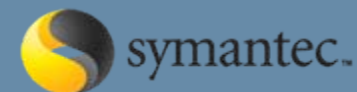


- From Hackers & Spies... To Thieves



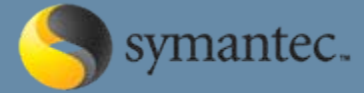
Moving from Disrupting Operations To Damaging Trust and Reputations

Protecting Information from what ?

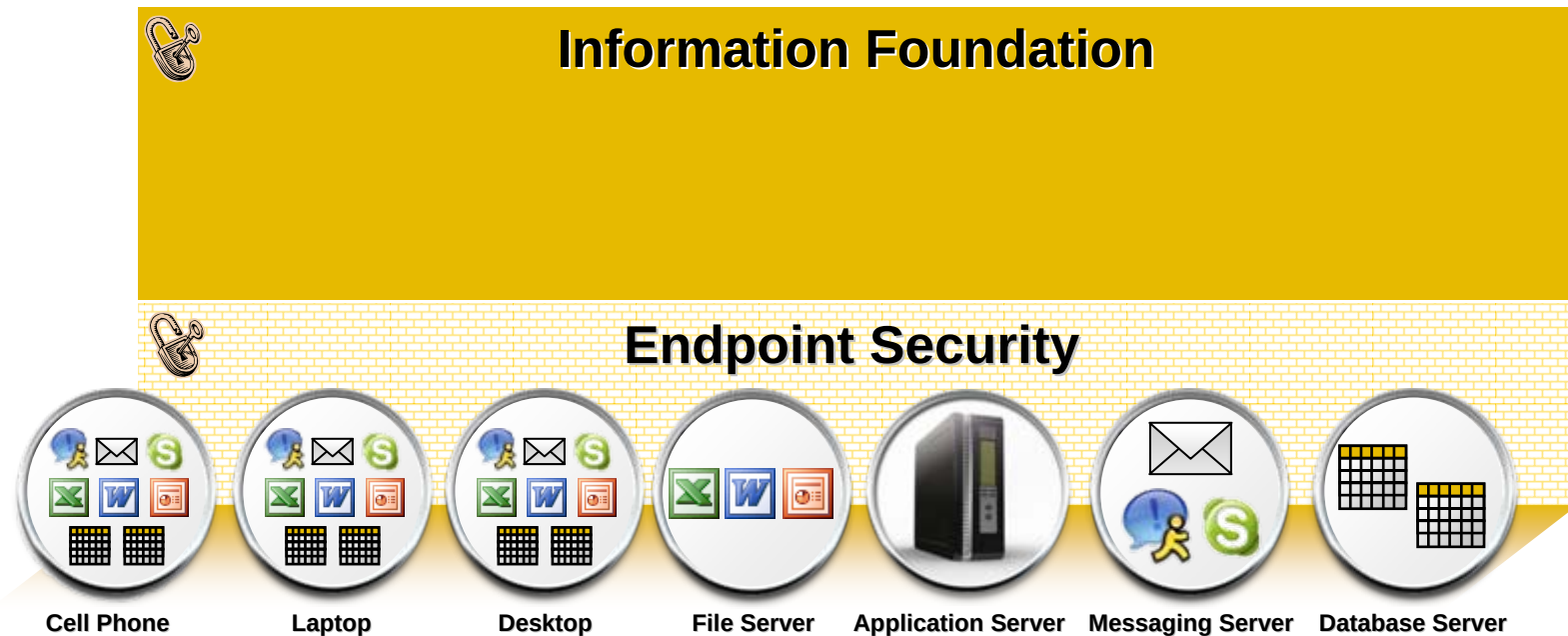


- **External Threats Such As Viruses, Spyware & Crimeware**
 - Exploiting System Vulnerabilities
- **Internal Threats Such As Data Theft and Data Leakage**
 - Exploit Lack Of Supervision For Corporate Information Flow
- **Non-Compliance With Policies Or Regulations (SOX, FISMA, etc)**
 - Lack Of Adequate Controls Or Evidence Collection

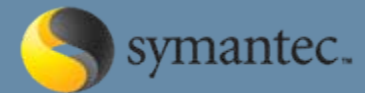
Endpoint Security & Information Foundation



- Provides A Real Time Defense Against Malicious Activity



A Complete Enterprise Security Strategy



Security Management



Information Foundation



Endpoint Security



Cell Phone



Laptop



Desktop



File Server



Application Server

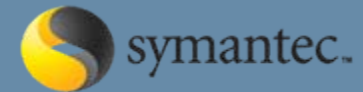


Messaging Server



Database Server

Endpoint protection technology



Antivirus & Antispyware

- Detect, block, and remove
 - Viruses
 - Spyware
 - Rootkits
 - Other malware

Antivirus & Antispyware

Network Threat Protection

Network Threat Protection

- Detect and block external threats
- Inbound and outbound filtering
- Location-aware policies

Proactive Threat Protection

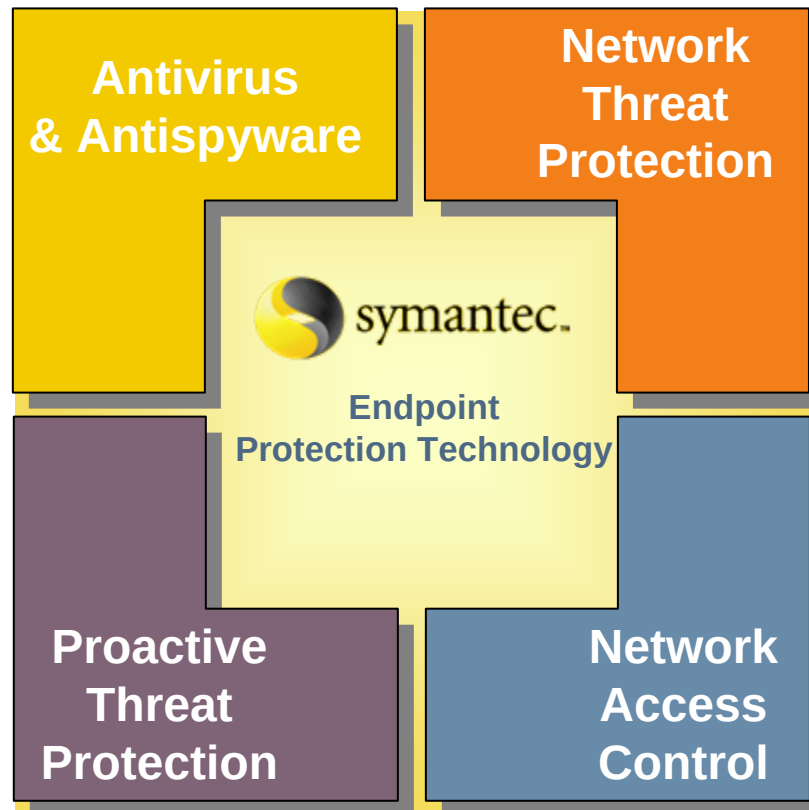
- Protect against 0-day threats
- Block device access based on policy

Proactive Threat Protection

Network Access Control

Network Access Control

- Enforce policy compliance for endpoints
- Block unauthorized endpoints from access
- Prevent compromises from remote employees





Virus



SpyWare



Worm

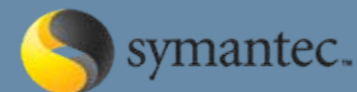


Crimeware

Antivirus & Antispyware Key Features

- Best-of-breed malware protection
 - Enhanced real-time detection and blocking
 - Automated removal
- Enhanced spyware protection
- New rootkit protection
- Improved performance
 - Greater protection with reduced system impact
- New client user interface

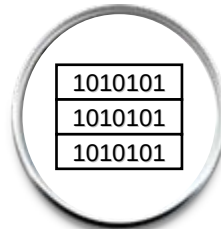
Network Threat Protection Features



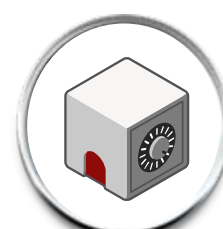
Back Door



Blended Threat



Buffer Overflow

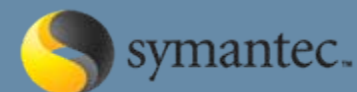


Known Exploits

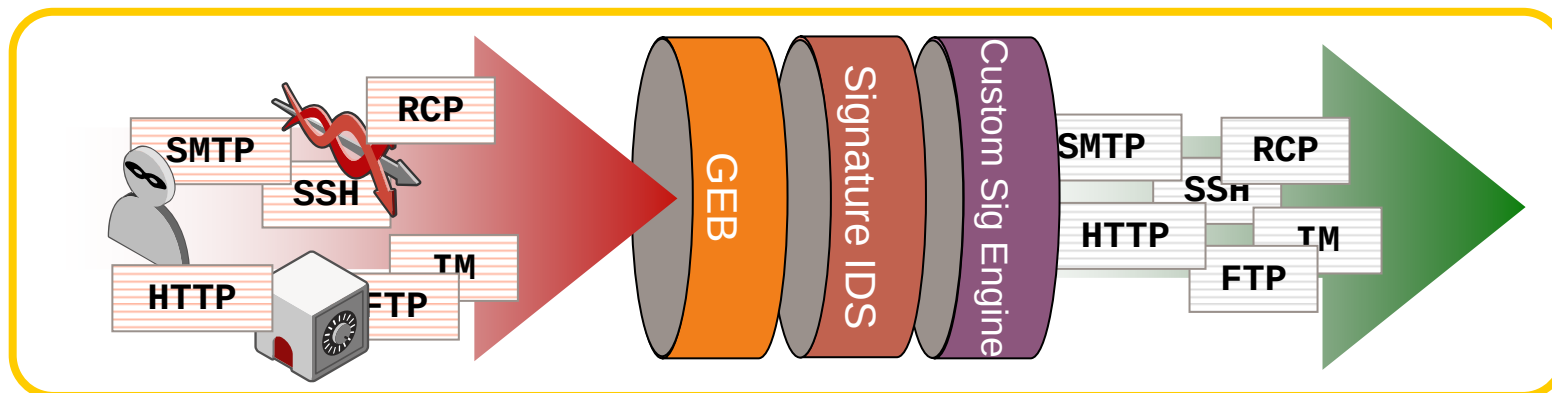
Network Threat Protection Key Features

- Best-of breed rule-based firewall engine
 - Adapter specific rules
 - Inspects encrypted and cleartext network traffic
- IPS engine
 - Generic Exploit Blocking (GEB)
 - Packet- and stream-based IPS
 - Custom IPS signatures similar to Snort™
- Location awareness

Intrusion Prevention System



```
rule tcp, tcp_flag&ack, daddr=$LOCALHOST, msg="[182.1] RPC DCOM buffer  
overflow attempt detected", content="\x05\x00\x00\x03\x10\x00\x00\x00"(0,8)
```



Intrusion Prevention Features

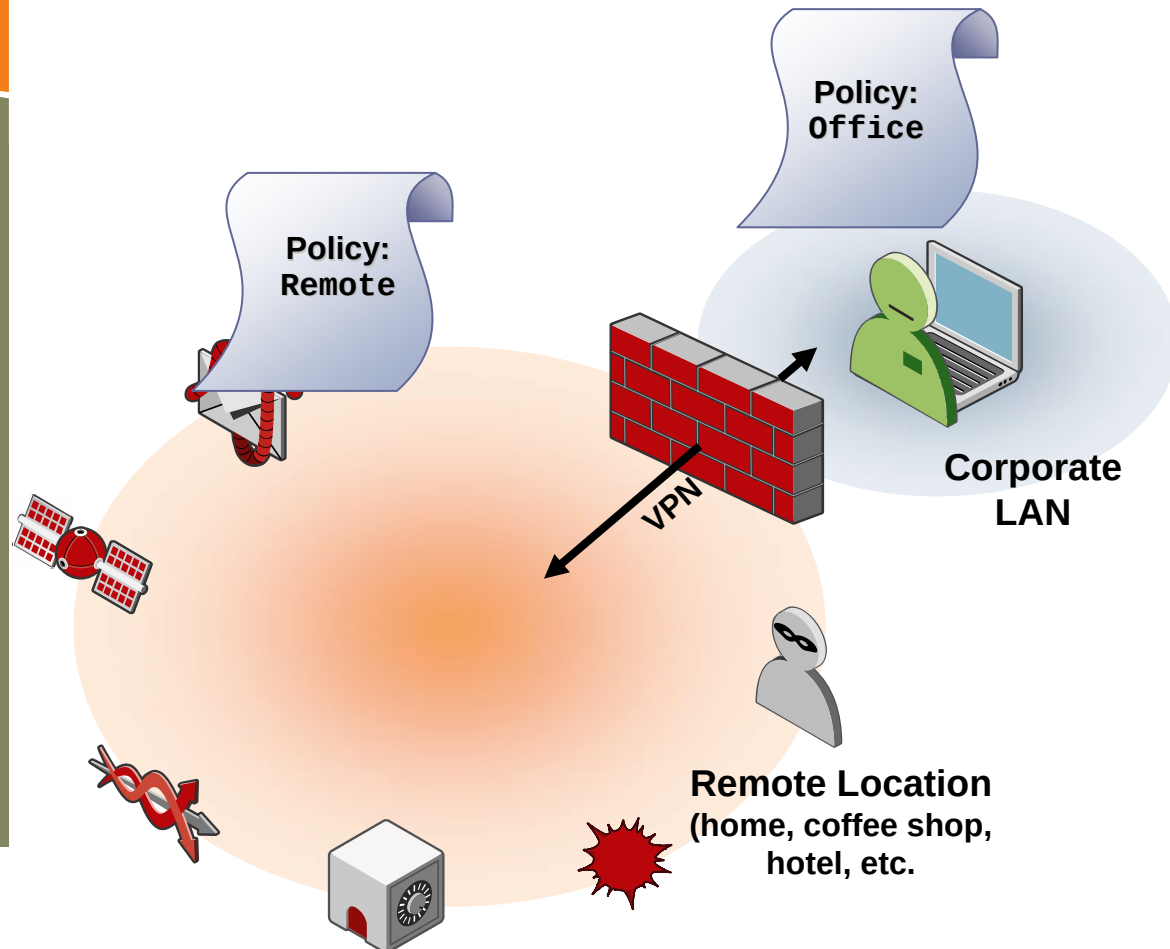
- Combines Generic Exploit Blocking (GEB) and SCS IDS with Sygate IDS
- Deep packet inspection
- Sygate IDS engine allows admins to create their own signatures
 - Uses signature format similar to SNORT™
 - Regex support
 - Signatures applied only to vulnerable applications
- Resistant to common and advanced evasion techniques

AutoLocation Switching Enhancements symantec.

AutoLocation Triggers

- IP address (range or mask)
- DNS server
- DHCP server
- WINS server
- Gateway address
- TMP token exists (hw token)
- DNS name resolves to IP
- Policy Manager connected
- Network connection type (wireless, VPN, Ethernet, dial-up)

Supports and/or relationships





**Non-Compliant
Endpoints**



Remote Workers



**Unauthorized
Endpoints**



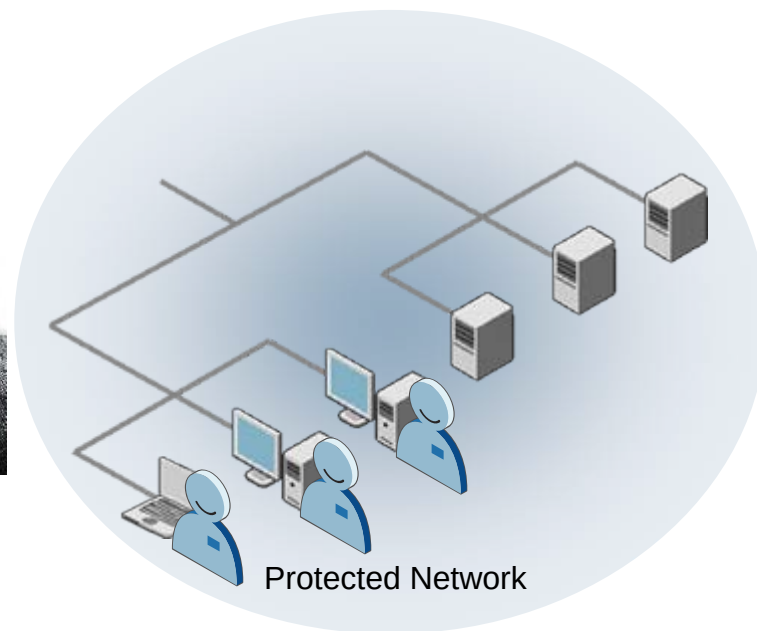
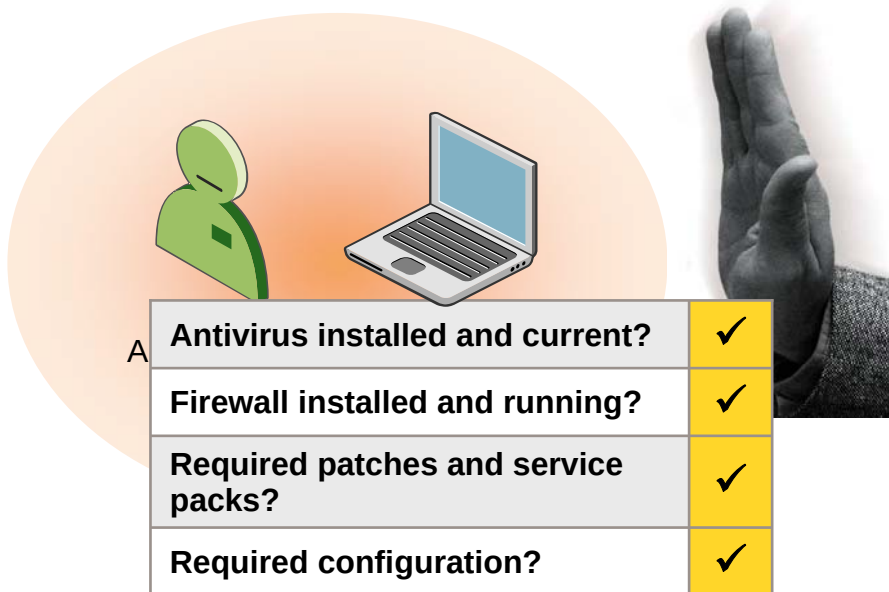
**Wireless
Networks**

Network Access Control Key Features

- NAC-ready endpoint protection
- Endpoint Compliance assessment and remediation
- Predefined Antivirus, Antispyware and personal firewall checks
- Vendor agnostic – can use another vendor's AV, AS or PFW
- Predefined OS and Service Pack checks
- Best-of-breed Configuration Check capability
- Most comprehensive range of NAC approaches

Authorizing Endpoints, Not Just Users

- Network Access Control = Control who can access your network by creating a closed system
- Ensure that required patches, configuration, and protection signatures are in place before the endpoint connects to the network
- Automatic endpoint remediation
 - Enforce policy *before* access is granted





Proactive Threat Protection Key Features

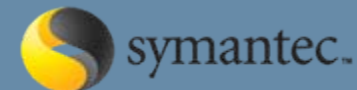
- Behavioral threat protection
 - Complete integration of Whole Security Confidence Online
 - Non-signature based malware detection and blocking
 - Protection from 0-day attacks
- Device Control
 - Block peripheral devices
 - Block read, write and execute
- System Lockdown and OS Protection harden the local file system and applications

System Lockdown Features

- Prevents unauthorized code from running on protected system
 - Malware
 - Unauthorized applications
- Creates a Digital Inventory of the system
 - Checksum.exe tool builds inventory
 - Create multiple inventories per server
- Fingerprints all executables (exe, com, dll, ocx, etc.)
- Block anything not on the list from execution



Proactive Threat Protection: Behavioral Detection Engine



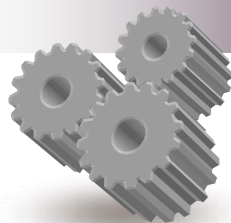
Enumerate processes

Enumerate all processes & embedded components



Analyze process behavior

Assess behavior & characteristics of each process



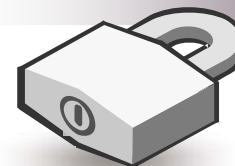
Score each process

Detection routines are weighted & processes are classified



Automatic protection

Malicious code is identified, reported & automatically mitigated



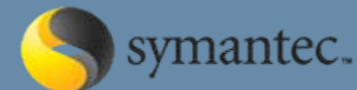
Each Engine has two sets of detection modules:

- Pro-valid = evidence of valid application behavior
- Pro-malicious = evidence of malicious application behavior

Each process gets 2 scores:

- Valid Score = measure of how valid the process is
- Malicious Score = measure of how malicious the process is

OS Protection (OSP)



Application Behavior Analysis

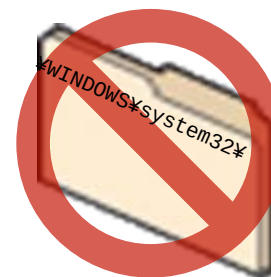
Monitors behavior or applications

Process Execution Control

Blocks unwanted programs from running

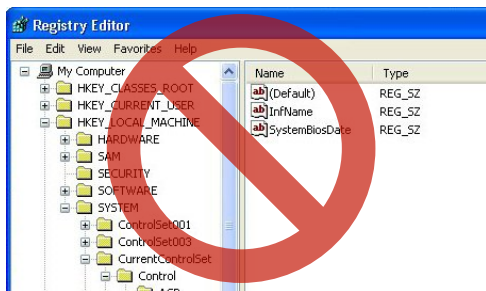
File Access Control

Blocks unwanted access to files or folders



Registry Access Control

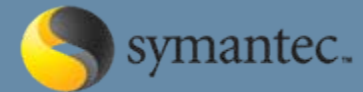
Controls access and writing to registry keys



Module & DLL Loading Control

Blocks applications from loading modules

Endpoint protection technology



Antivirus & Antispyware

- Detect, block, and remove
 - Viruses
 - Spyware
 - Rootkits
 - Other malware

Antivirus & Antispyware

Network Threat Protection

Network Threat Protection

- Detect and block external threats
- Inbound and outbound filtering
- Location-aware policies

Proactive Threat Protection

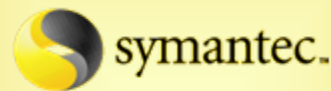
- Protect against 0-day threats
- Block device access based on policy

Proactive Threat Protection

Network Access Control

Network Access Control

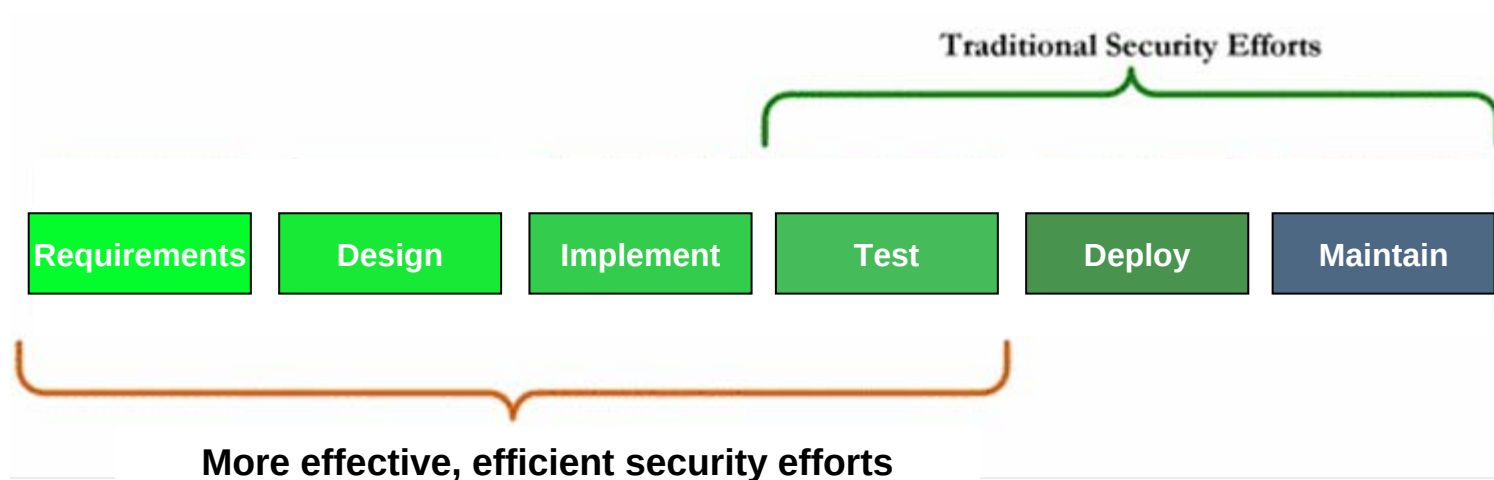
- Enforce policy compliance for endpoints
- Block unauthorized endpoints from access
- Prevent compromises from remote employees



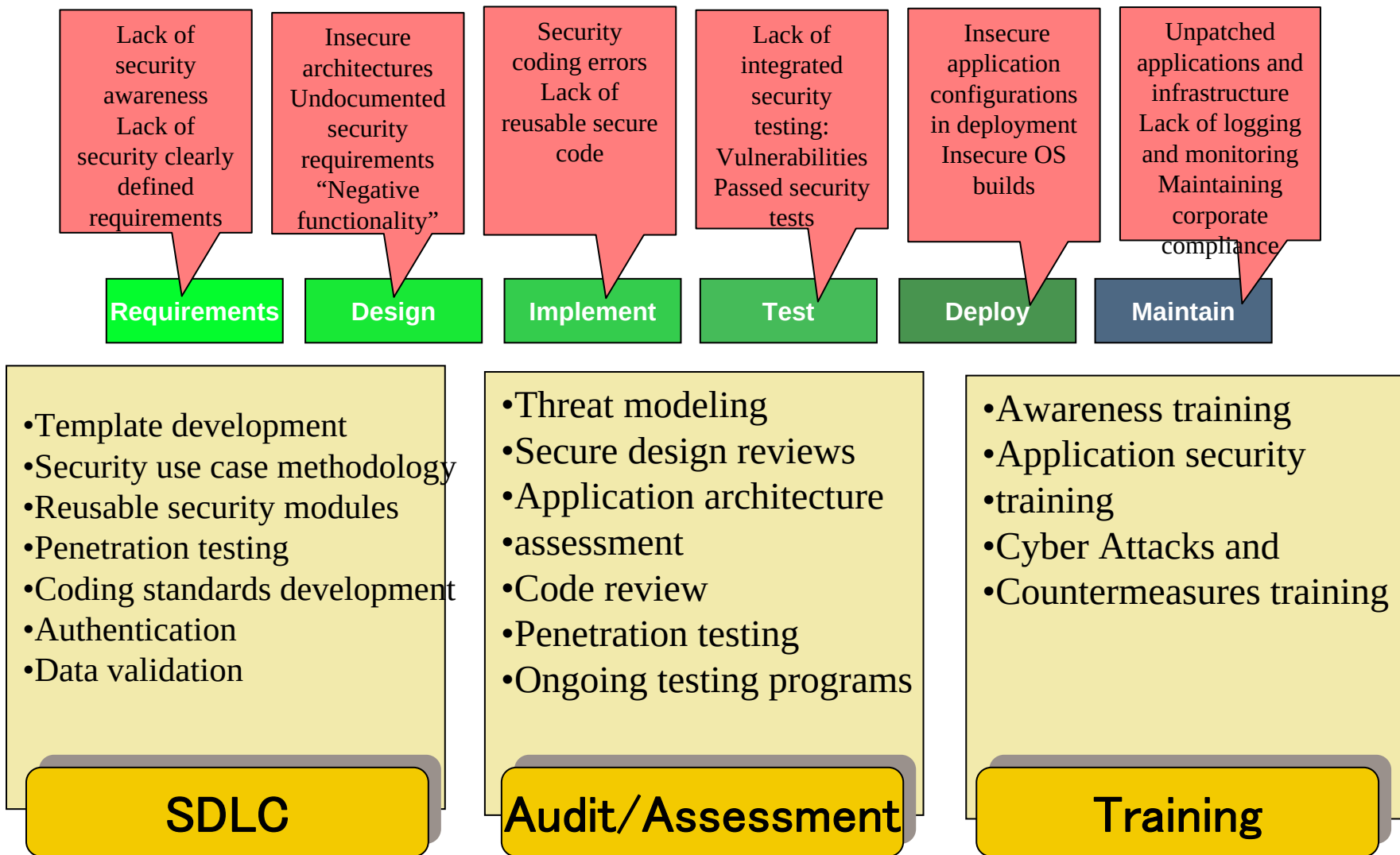
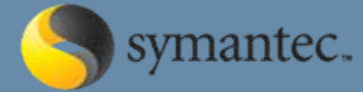
Endpoint
Protection Technology

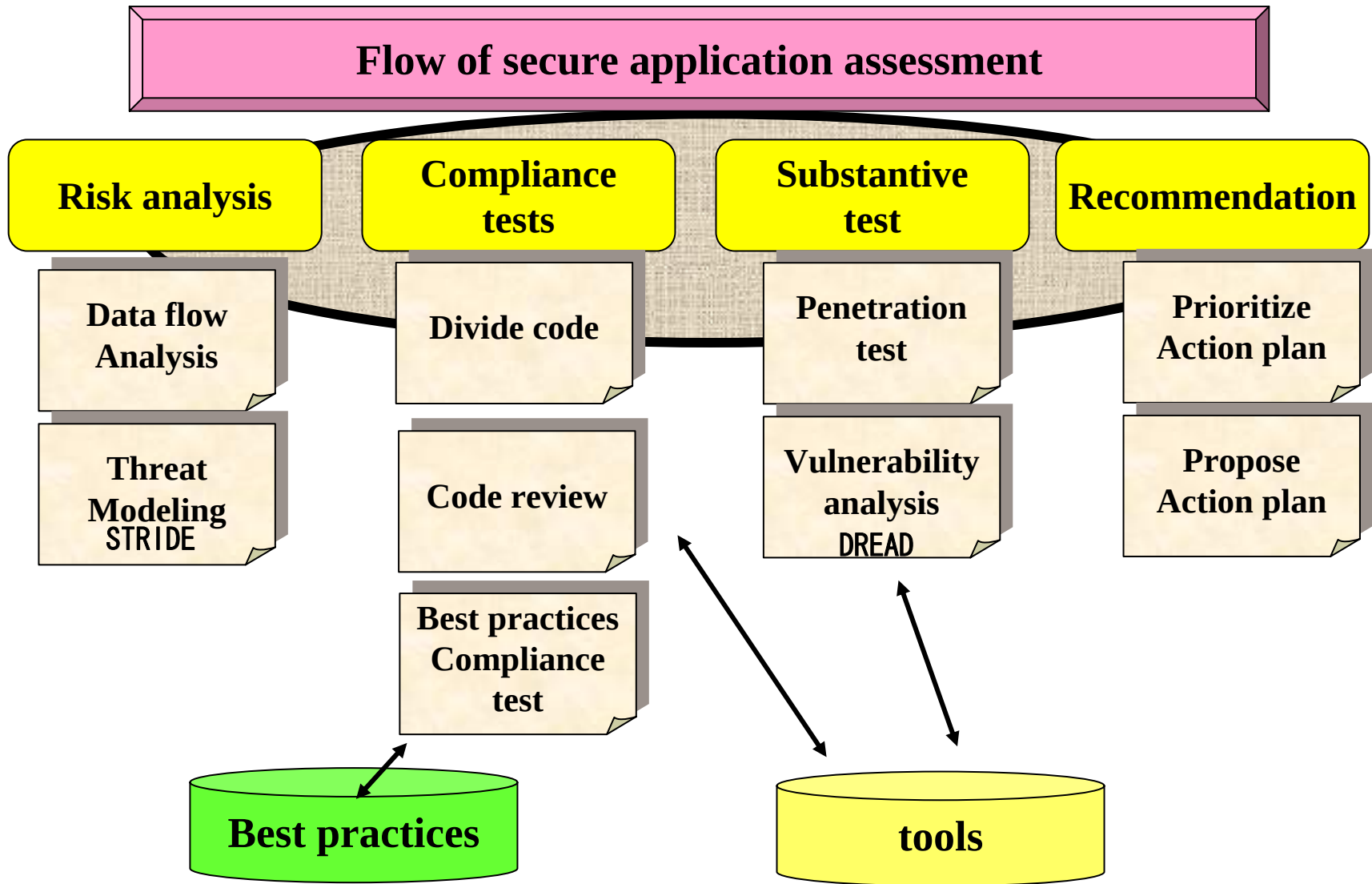
Traditional application and product security efforts are focused on test, deploy and maintenance phases...

Traditional security efforts



Outline of Secure Application development





1 Internet Security Threat Report

2 Attack Trends

3 Vulnerability Trends

4 Malicious Code Trends

5 Counter measures



Confidence in a connected world.



Thank You!

tadashi_yamanouchi@symantec.com

Copyright © 2007 Symantec Corporation. All rights reserved. Symantec and the Symantec Logo are trademarks or registered trademarks of Symantec Corporation or its affiliates in the U.S. and other countries. Other names may be trademarks of their respective owners. This document is provided for informational purposes only and is not intended as advertising. All warranties relating to the information in this document, either express or implied, are disclaimed to the maximum extent allowed by law. The information in this document is subject to change without notice.